Saudi GRC Platform

Ai Features

Source: `ai-features.md`

16 — AI-Assisted Features

Fifteen LLM-assisted capabilities for the TSS GRC platform. Each is built as an opt-in feature behind a "Suggest with AI" button — never as a silent automation. Every output is treated as a *draft* and routed through the existing approval workflow.

Cross-cutting design principles (apply to every feature):

Principle	Enforcement
Human-in-the-loop	Every AI output is editable + requires a human reviewer to save / approve
Provenance	Each AI-generated field stamped with model name + version + prompt-id + invocation timestamp in ai.invocations (audit log)
Confidence + grounding	Outputs include cited sources (regulatory clauses, prior records, evidence ids) and a confidence score
Bilingual	Prompt scaffolding accepts EN or AR; outputs match the user's lang setting
Data privacy	Personal data is masked before sending to the LLM; PDPL transfer log written if cross-border
Tenant scope	The retrieval layer filters every prompt context to organisationId so cross-tenant leakage is impossible
Provider portability	One AiProvider interface; Saudi-region providers preferred (e.g. STC AI, Azure UAE/KSA region OpenAI)
Off-switch	Tenant admin can toggle the entire AI suite or per-feature

---

17.1 Risk description generation

Attribute	Value
Feature name	Risk-description copilot
User problem	Risk owners write descriptions inconsistently; some are one line, others verbose. Auditors mark this as a control weakness during NCA / ISO 31000 assessment
Required input	Risk title, category, related asset/process, identified-by source (audit finding / KRI / incident), prior similar risks from the org's register, regulator hints (e.g. NCA ECC domain)
AI output	Two paragraphs — (1) plain-language description with named threat + vulnerability + exposed asset, (2) "current control posture" pointing to controls already linked to the asset
Human review	Required. Editable; Risk Owner approves before saving
Approval requirement	At RISK_ASSESSED transition (Risk Manager)
Hallucination risk	Medium — model may invent regulator clauses or controls. Mitigated by retrieval grounding
Guardrails	(a) Output limited to ≤ 1,800 chars; (b) inline citations to retrieved sources required; (c) refuses if input contains real personal-data values; (d) blocked terms list (no "we" / "your organisation" — third-person factual only)

Attribute	Value
Audit log	ai.invocations row with prompt hash, output hash, reviewer userId, accept/reject, time
Privacy	No PII forwarded — input is structured metadata only. Free-text risk title is screened for pii_detector before send.

17.2 Risk cause and consequence suggestions

Attribute	Value
Feature name	Cause-and-consequence advisor
User problem	Cause / consequence sections of risk records are often left blank; root-cause work happens too late, after incidents
Input	Risk record + linked control set + recent incidents touching the same assets + sector-typical scenarios
Output	(1) Ranked list of plausible causes with weights; (2) consequence chain mapping to financial / regulatory / reputational / operational dimensions matching the BIA scoring scheme
Human review	Required — Risk Owner ticks the rows to keep
Approval	Persists with the risk; appears in board pack only after Risk Mgr sign-off
Hallucination risk	Medium — fabrication of incidents. Mitigated by grounding strictly on the org's own incident register
Guardrails	(a) Each suggestion must cite at least one source record id; (b) refuses to invent regulator deadlines; (c) bilingual output guarded against MT artifacts
Audit log	Same as 17.1
Privacy	Tenant-scoped retrieval; never reads other tenants' incidents

17.3 BIA impact recommendation

Attribute	Value
Feature name	BIA impact coach
User problem	Business Owners over- or under-rate impact dimensions inconsistently across services, weakening the BIA-driven prioritisation
Input	Service description, revenue dependency, customer-facing flag, regulatory drivers, peer-service ratings, historical incident downtime
Output	Suggested scores per impact dimension (financial / regulatory / reputational / operational) with a one-sentence rationale per dimension
Human review	Required — BIA Owner approves each dimension; original Service Owner must counter-sign
Approval	BIA Manager at IN_REVIEW → APPROVED
Hallucination risk	Low (scores are bounded 1-5) but rationale text can drift

Attribute	Value
Guardrails	(a) Numeric output must lie within configured min/max per dimension; (b) refuses if BIA already APPROVED (avoid silent re-scoring); (c) rationale capped 200 chars per dimension
Audit log	Stored alongside the BIA versioned record
Privacy	Aggregated metrics only; no individual customer data

17.4 RTO / RPO recommendation

Attribute	Value
Feature name	RTO-RPO advisor
User problem	RTO/RPO are often set by tradition rather than evidence; this creates BIA / DRP gaps
Input	Service criticality, MTPD, downstream-service map, current architecture (HA vs single-instance), regulator floor (e.g. SAMA outsourcing rules), peer benchmark band
Output	(1) Recommended RTO (hours) + RPO (hours) with rationale; (2) gap statement vs current DrPlan.rto_actual/rpo_actual; (3) suggested treatment if gap > 0
Human review	Required — DR Owner + BCM Manager both review
Approval	BCM Manager at BIA APPROVED
Hallucination risk	Low for numeric output, medium for the treatment narrative
Guardrails	(a) Numeric output must be a positive integer ≤ MTPD; (b) regulator-floor check before showing — never recommend below the floor; (c) rationale must cite retrieved source ids
Audit log	Yes; also stamps bcm.bia_records.ai_suggested_rto so reviewers can see drift over time
Privacy	No PII

17.5 Supplier risk-scoring suggestions

Attribute	Value
Feature name	Vendor-risk scoring copilot
User problem	Vendor risk-rating is heterogeneous across teams; some assessors are stricter than others, eroding comparability
Input	Vendor metadata (sector, country, criticality, services), latest TPRM cyber assessment, recent supplier incidents, fourth-party concentration, sanctions hit (SIMAH/Dow Jones)
Output	Suggested overall rating (LOW/MEDIUM/HIGH/CRITICAL) with weighted contributors visualised + 1-paragraph narrative
Human review	Required — Vendor Risk Manager
Approval	Mandatory before propagating into the TPRM cyber assessment auto-CAPA trigger
Hallucination risk	Low — output bounded enum

Attribute	Value
Guardrails	(a) Output is enum-bound; (b) narrative must cite contributor breakdown numerically; (c) refuses to upgrade above CRITICAL or downgrade below LOW
Audit log	Yes; tprm.cyber_assessments.ai_suggested_residual stamped
Privacy	Vendor PII screened before send; only structured metadata

17.6 PDPL PIA gap suggestions

Attribute	Value
Feature name	PIA gap finder
User problem	DPOs miss specific PDPL articles (Art. 25 PIA triggers, Art. 26 consultation rules) when assessing new processing activities
Input	Processing activity (ROPA row) + selected lawful basis + data categories + cross-border flag + linked processors
Output	Per-PDPL-article checklist with status (likely-MET / likely-GAP / needs-evidence) + suggested remediation step
Human review	Required — DPO
Approval	DPO at PIA APPROVED
Hallucination risk	Medium — model may misclassify lawful basis. Mitigated by retrieving the PDPL article text from compliance.requirements at prompt time
Guardrails	(a) Each gap must cite a PDPL article id; (b) only suggests articles already loaded in the platform's regulatory library — no inventing; (c) refuses to assert "compliant" — only "likely met pending evidence"
Audit log	Yes; suggested gaps that the DPO accepts spawn CAPA tasks with originType=pia_gap
Privacy	Processing-activity metadata only; no real subject data

17.7 NCA compliance gap analysis

Attribute	Value
Feature name	NCA gap analyser
User problem	Annual NCA self-assessment is a manual exercise per control; CISOs need a first-pass gap analysis to focus reviewer time
Input	Cyber control library (the 145 seeded controls + sub-controls), per-control evidence linkage, recent assessment notes, framework version
Output	Per-control predicted implementation status (IMPLEMENTED / PARTIAL / PLANNED / NOT_IMPLEMENTED / NOT_APPLICABLE) + per-control evidence-gap explanation + a domain-level maturity-tier projection

Attribute	Value
Human review	Required for every control before filing; CISO sign-off
Approval	CISO at NCA filing SUBMITTED
Hallucination risk	High — easy to invent compliance. Mitigated by requiring at least one linked evidence id per "IMPLEMENTED" suggestion
Guardrails	(a) Refuses to mark "IMPLEMENTED" without ≥ 1 linked evidence; (b) blocks output that contradicts a recent assessor note flagged as authoritative; (c) regulator-citation required per control
Audit log	Full; the filing PDF lists each AI-suggested control vs CISO-accepted control
Privacy	No PII

17.8 Evidence quality review

Attribute	Value
Feature name	Evidence reviewer
User problem	Auditors find evidence packs are stale, unsigned, or missing scope context
Input	Evidence item + version + its chain-of-custody status + linked controls + the requirement text it should support
Output	(1) Quality score (0-5), (2) per-defect list (date stale, no signature, scope mismatch, etc.), (3) suggested remediation
Human review	Required — Evidence Owner
Approval	At evidence APPROVE transition
Hallucination risk	Low for score, medium for defect narrative
Guardrails	(a) Score bounded 0-5; (b) does not download or parse the actual file unless tenant has explicitly enabled file-content review (off by default for sensitive evidence); (c) only references defects against the linked control's stated requirement
Audit log	Per-version, including the prompt and the auto-checks (date, sig, hash chain) it performed deterministically before invoking the LLM
Privacy	Optional file-content review respects evidence ACL; staff under the tenant's EVIDENCE_READ_RESTRICTED role can be excluded

17.9 Corrective action recommendation

Attribute	Value
Feature name	CAPA advisor
User problem	CAPA owners draft thin action statements; the system can't track meaningful progress against vague language

Attribute	Value
Input	Source record (incident / audit finding / KRI breach / failed assessment) + similar past CAPAs (closed, resolved) + the linked control
Output	SMART action statement (Specific, Measurable, Achievable, Relevant, Time-bound) + target date + suggested owner role
Human review	Required — CAPA Owner
Approval	At CAPA create + at AWAITING_VERIFICATION
Hallucination risk	Medium
Guardrails	(a) Target date inside policy window per severity (e.g. CRITICAL ≤ 45d); (b) owner suggestion is a role, not a named user (avoid name fabrication); (c) refuses if source record is in a state that doesn't allow CAPA creation
Audit log	Yes
Privacy	No PII

17.10 Executive report drafting

Attribute	Value
Feature name	Executive narrative writer
User problem	Exec teams need a clean 1-page narrative on top of the dashboard numbers; analysts spend hours writing it
Input	Selected dashboard KPIs, current quarter risk trends, top-5 movers, regulator-deadline calendar
Output	One-page narrative (≤ 600 words) with sections: headline, top risks, compliance posture, BCM readiness, supplier resilience, ask-of-the-exec
Human review	Required — Compliance Officer / Risk Mgr
Approval	Before any distribution beyond owner
Hallucination risk	High — risk of stating outcomes not in the data
Guardrails	(a) Output must include numeric figures only from the supplied KPI set; (b) "ask-of-the-exec" section requires referencing a real open CAPA or above-appetite risk; (c) no projection beyond next quarter
Audit log	Yes; the published version is signed by reviewer + content-hashed
Privacy	Tenant-scoped, no PII

17.11 Board summary drafting

Attribute	Value
Feature name	Board-pack narrative writer
User problem	Same as 17.10 but for the Board: governance language, less detail, more decisions-to-take

Attribute	Value
Input	Board pack draft (numeric sections) + previous quarter's signed pack
Output	Three sections: (1) "Decisions taken since last meeting", (2) "Material risks + acceptance candidates", (3) "Items for board decision"
Human review	Required — Board Secretary + CRO
Approval	Chairman digital signature before distribution
Hallucination risk	High (board-level statements)
Guardrails	(a) Outputs only when the underlying KPIs are signed off; (b) explicit refusal of any forward-looking statement that isn't already in an approved plan; (c) board-tone enforced via prompt + reviewer check
Audit log	Yes; included in the signed board pack
Privacy	No PII; cross-border AI calls disabled if the tenant is in SENSITIVE mode

17.12 Regulatory change impact analysis

Attribute	Value
Feature name	Reg-change impact analyser
User problem	NCA / SDAIA / SAMA / CMA push out reg updates; compliance teams take weeks to map them
Input	The reg-change text (ingested via RegulatoryChange module) + the platform's current control + policy library
Output	(1) Affected requirements list, (2) per-requirement implementation gap, (3) suggested CAPA themes
Human review	Required — Compliance Officer
Approval	Before any auto-CAPA generation
Hallucination risk	High
Guardrails	(a) Only references requirements already in compliance.requirements; (b) refuses to map to specific control IDs unless a textual match score > threshold; (c) all CAPA themes routed to draft, never auto-created
Audit log	Yes
Privacy	No PII

17.13 Incident root-cause draft

Attribute	Value
Feature name	RCA draft assistant
User problem	RCAs are time-consuming; the 5-Whys / Fishbone / Pareto methodology is well-defined but tedious
Input	Incident timeline entries, impacted assets, contributing factors free-text, linked vulnerabilities

Attribute	Value
Output	Methodology-specific draft (5-Whys chain / Fishbone branches / Pareto top-3) + root-cause statement + recommendations list
Human review	Required — RCA Facilitator
Approval	RCA APPROVED workflow gate
Hallucination risk	Medium
Guardrails	(a) Each "why" must cite a timeline-event id; (b) no hindsight bias — output must answer "what was knowable when?"; (c) recommendations always require a target date placeholder
Audit log	Yes
Privacy	Incident-touching subject data masked before send

17.14 Lessons-learned extraction

Attribute	Value
Feature name	Lessons distiller
User problem	After-action reports are written but rarely re-used; lessons stay locked in PDFs
Input	Approved RCAs + exercise after-action reports + closed CAPAs from the last 24 months
Output	Themed lessons-library (e.g. "Phishing — top 3 recurring causes") with citations back to source records
Human review	Required — Risk Mgr + BCM Mgr
Approval	Before publication to Knowledge Base
Hallucination risk	Medium
Guardrails	(a) Each lesson must cite ≥ 2 source records; (b) refuses to publish a lesson contradicted by an unresolved exception; (c) freshness — lessons referencing > 24-month-old records are flagged for re-validation
Audit log	Yes; lessons get a content hash so the source-record link is tamper-evident
Privacy	Subject identifiers redacted in published lessons

17.15 Control mapping suggestions

Attribute	Value
Feature name	Control-mapping copilot
User problem	When a new framework (e.g. SAMA Cyber update) is imported, mapping its controls to existing ones is slow + error-prone
Input	Imported framework's controls (text) + the platform's existing control library

Attribute	Value
Output	Per-imported-control: top-3 candidate mappings with similarity score + rationale + suggested action (NEW / REUSE / VARIANT)
Human review	Required — Control Owner
Approval	Compliance Officer at framework-activation
Hallucination risk	Low-medium (score-grounded)
Guardrails	(a) Similarity score must exceed threshold; (b) refuses to mark as REUSE if the candidate is currently in DEPRECATED state; (c) ≤ 3 candidates per source, never more
Audit log	Yes
Privacy	No PII

AI invocation table (cross-cutting persistence)

Every invocation persists a row to `ai.invocations`:

Column	Meaning
id	PK
organisation_id	tenant scope
feature_code	e.g. risk_description, pia_gap_finder
provider	OPENAI_KSA / STC_AI / AZURE_UAE_NORTH etc.
model	gpt-4-turbo etc.
prompt_hash	sha256 of full prompt
output_hash	sha256 of returned output
input_token_count	for cost tracking
output_token_count	for cost tracking
latency_ms	observed latency
cost_sar	computed
entity_type + entity_id	what the output was attached to
reviewer_user_id	who accepted/rejected
decision	ACCEPTED / EDITED / REJECTED
accepted_at	timestamp
created_at	invocation time

The `ai.invocations` table is included in the data-model spec (output 4) and gets the standard `BaseEntity` audit columns. Auditors can read this table; tenant admins can purge older than retention (default 36 months).

Provider abstraction

Java interface (suggested addition to backend):

```
public interface AiProvider {
AiResponse complete(AiPrompt prompt);
boolean supportsRegion(String region); // e.g. SA, AE, EU
String modelName();
String providerName();
}
```

Implementations: `OpenAiKsaProvider`, `StcAiProvider`, `AzureUaeNorthProvider`, `OfflineProvider` (returns a deterministic stub for dev / tests). Selection driven by per-tenant config `ai.provider.preferred`.

Privacy gating

Two layers before every send:

1. **PII detector** (`PiiDetector`) — uses regex + ML model offline to classify Saudi National-ID, IBAN, MOI passport, mobile, etc. If any are present, the call is blocked or the values are masked with a reversible per-tenant token.
2. **Cross-border transfer log** — if the chosen provider is hosted outside KSA and the tenant's data-residency policy is `KSA_ONLY`, the call is blocked. Otherwise a row is written to `privacy.cross_border_transfers` with `mechanism=AI_INVOCATION`.

Off-switch

`SettingsPage` → AI tab exposes: - Master toggle (per tenant). - Per-feature toggles (15 switches). - Provider override. - Per-feature daily-call cap. - Per-feature daily-cost cap. - "Send debug invocations to provider X" toggle for tenant security team.

When the master toggle is off, the "Suggest with AI" buttons render as disabled with a hover tooltip "AI features disabled by your tenant administrator".